ONE-PAGE BRIEF

Post-quantum cryptography review: librustzcash @ 8672a4b2d60f

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/librustzcash, commit `8672a4b2d60f` · Reviewed: 2026-11-04 18:53 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **2** High **10** Medium
32 Low **7** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-12007	**rustls-webpki 0.101.7 is affected by GHSA-82j2-j2ch-gfr8 (CVE-2026-93599, RUSTSEC-2026-0104)** What to do: Upgrade to a fixed version (0.103.13, 0.104.0-alpha.7).
High QSI-2026-12011	**rustls-webpki 0.103.3 is affected by GHSA-82j2-j2ch-gfr8 (CVE-2026-93599, RUSTSEC-2026-0104)** What to do: Upgrade to a fixed version (0.103.13, 0.104.0-alpha.7).
Medium QSI-2026-12016	**serde_with 3.16.0 is affected by GHSA-7gcf-g7xr-8hxj** What to do: Upgrade to a fixed version (3.21.0).
Medium QSI-2026-11980	**Quantum-vulnerable Pedersen commitment: threshold signing and MPC protocols (4 file(s))** preliminary What to do: Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the signature scheme; record which keys…

40 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium threshold signing and MPC protocols	Pedersen commitment	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the…
Medium transaction and message signing	ECDSA, BLS12-381	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 42; unlikely to apply to this build: 14 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 28.

Static review of source code and manifests; files analysed: 333. No requests were sent to the owner's systems.

Full report, content SHA-256: `73e519d78fa75b6532dd27be4f97c2d412b518f965e6cc5b154f9663f742ece0`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.